



Allowed Domains Audit

Generated at — July 20, 2026, 1:56 p.m.

If a client includes their own clients' domains in their allow lists, it's important to understand the risk this creates. **When one of those trusted domains becomes compromised**, any malicious email sent from that domain will bypass Microsoft 365's spam and phishing filters and be delivered directly to users' inboxes, greatly increasing the chances of account compromise.

This is especially dangerous because attackers often exploit trust relationships. A compromised vendor or partner account can be used to send targeted, high-trust phishing or malware-laced emails that evade detection due to allow list bypasses.

To reduce this risk:

- Avoid blanket domain-level allow list entries unless absolutely necessary.
- Regularly audit allow lists across **anti-spam policies, connection filters, and mail flow rules**.
- Consolidate and manage allow/block entries through **Microsoft Defender threat policies**, which provide better visibility and control.

Properly scoping exceptions and using Defender's centralized policy management helps prevent misaligned or overly permissive configurations that attackers can exploit.

1 Microsoft Defender



security.microsoft.com/antispam

Microsoft Defender for Office 365 is the recommended centralized location for managing email allow and block lists, ensuring consistent and secure filtering across the environment.

Policies & rules > Threat policies > Anti-spam policies

Anti-spam policies

Use this page to configure policies that are included in anti-spam protection. These policies include connection filtering, spam filtering, and outbound spam filtering.

+ Create policy Refresh

Name	Status
☐ Standard Preset Security Policy	On
☒ Anti-spam inbound policy (Default) 1	Always on
☐ Connection filter policy (Default)	Always on
☐ Anti-spam outbound policy (Default)	Always on

Anti-spam inbound policy (Default)

Always on | Priority Lowest

Bulk message action
Move message to Junk Email folder

Intra-Organizational messages to take action on
Default

Enable spam safety tips
On

Enable for spam messages
On

Enable for phishing messages
On

Retain spam in quarantine for this many days
15

[Edit actions](#)

Allowed and blocked senders and domains

Allowed senders
31 senders

Allowed domains
34 domains

Blocked senders
23 senders

Blocked domains
9 domains

[Edit allowed and blocked senders and domains](#) 2

[Close](#)

Scroll to the bottom

Tip: Use PowerShell to export the allowed domains (Get-HostedContentFilterPolicy -Identity "Default" | select AllowedSenderDomains).AllowedSenderDomains | select Domain | Export-Csv c:\temp\alloweddomains.csv

2 LEGACY - Exchange Mail Flow Rules



admin.exchange.microsoft.com/#/transportrules

Before Microsoft Defender for Office 365, administrators commonly used transport rules or connection filters to bypass spam filtering, such as by creating allow lists. However, Defender is now the recommended standard for managing these exceptions, offering centralized control, better visibility, and improved protection.

Here is an example of a mail flow rule that bypasses spam filtering:

Home > Rules

DLP policies and DLP-related conditions and actions in Mail flow rules are no longer supported and can no longer be created or edited in the Exchange Admin Center (EAC). Purview DLP in the compliance center as soon as possible. Once you have migrated these rules please delete them here in the EAC or via PowerShell. Learn more: [Migrate DLP](#)

Rules

Add, edit, or make other changes to your transport rules. [Learn more about transport rules](#)

+ Add a rule

Edit

Duplicate

Delete

Refresh

Move up

Move down

Status	Rule	Priority	Stop processing rules	Size (B)
☐ Disabled	Block HTM/HTML Attachments (Do Not Enable)	0	×	640
☐ Enabled	Received from 'brianmercer152@gmail.com' 2	1	×	299
☐ Enabled	Received from 'satake@bitters.co.jp'	2	×	280
☐ Enabled	Received from 'gifohty@gmail.com'	3	×	372
☒ Enabled	received from marjoriev@stellarpainspine.com- T20250428.0127	4	×	546

received from marjoriev@stellarpainspine.com- T202...

Edit rule conditions

Edit rule settings

Status: Enabled

Enable or disable rule

☒ Enabled

Rule settings

Rule name

received from marjoriev@stellarpainspine.com- T20250428.0127

Severity

Not specified

Senders address

Matching Header

For rule processing errors

Ignore

Mode

Enforce

Set date range

Specific date range is not set

Priority

4

Rule description

Apply this rule if

Is received from 'marjoriev@stellarpainspine.com'

Do the following

Set the spam confidence level (SCL) to '-1'

Rule comments

ticket - T20250428.0127 - marjoriev@stellarpainspine.com emails are getting quarantined even after submitting to MS for false positive.

PA: If mailflow rules are found that bypass spam filtering, make the SA aware that consolidation or cleanup is needed to move the entries to Defender policies instead.

XL.net